

Clase 164 — Diseño de infraestructura de comando y control (C2)

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *Red Team Development and Operations (Vest & Tubberville)* · Duración estimada: **110 min** · Nivel: **Avanzado**

Objetivo

Diseñar infraestructura de C2 resiliente y sigilosa: la red de servidores, redirectores, dominios y canales que un operador usa para controlar sus implantes sin exponer el servidor de comando ni facilitar el bloqueo por parte del defensor. El alumno entenderá la arquitectura por capas, el uso de redirectores, la categorización de dominios y la separación de infraestructura por función.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Explicar** la arquitectura por capas de una operación (team server, redirectores, dominios).
- 2. **Configurar** un redirector HTTP/HTTPS que oculte el team server.
- 3. **Seleccionar** y categorizar dominios para mimetizar tráfico legítimo.
- 4. **Separar** la infraestructura de staging, C2 de largo plazo y exfiltración.
- 5. **Diseñar** un plan de resiliencia ante bloqueos (rotación, canales alternativos).

Temas

#	Tema	Por qué importa
1	Team server	Cerebro de la operación; nunca se expone directo
2	Redirectores	Ocultan el team server y filtran tráfico
3	Categorización de dominios	Tráfico que "parece" legítimo evade filtros
4	Canales (HTTPS, DNS, SMB)	Distintos perfiles de sigilo y fiabilidad
5	Domain fronting / CDN	Ofusca el destino real del tráfico
6	Separación por función	Un dominio quemado no tumba toda la operación
7	Resiliencia y rotación	Sobrevivir al bloqueo del defensor

Definiciones y características

- **Team server:** servidor central que gestiona implantes y operadores. Característica: se protege tras redirectores, nunca recibe tráfico del objetivo directamente.
- **Redirector:** proxy (socat, Apache mod_rewrite, Nginx) que reenvía tráfico válido al team server y descarta el resto. Característica: es sacrificable.

- **Long-haul vs short-haul C2:** canales lentos y sigilosos (persistencia) vs rápidos (trabajo interactivo). Característica: se combinan para equilibrar sigilo y agilidad.
- **Domain fronting:** usar el SNI/host de un CDN legítimo para ocultar el destino real. Característica: cada vez más limitado por los proveedores.
- **Malleable profile:** configuración que define cómo se ve el tráfico C2 (headers, URIs, jitter). Característica: mimetiza aplicaciones legítimas.
- **Categorización de dominio:** clasificar un dominio como "business/health" ante proxies web. Característica: evita bloqueos por reputación.

Herramientas y preparación

- Un VPS de laboratorio (o VMs locales) para team server y redirectores.
- `socat`, `nginx` / `apache2` para redirectores; `certbot` para TLS válido.
- Un dominio de práctica (o `/etc/hosts` en el lab para simular resolución).
- Frameworks C2 que veremos en la Clase 165 (Sliver/Mythic) como consumidores de esta infraestructura.
- Terraform/Ansible (opcional) para automatizar el despliegue reproducible.

⚠ Toda esta infraestructura se despliega en tu propio laboratorio o en VPS que controlas legítimamente, para dirigir implantes hacia máquinas de tu lab. Nunca apuntes redirectores hacia objetivos sin autorización escrita.

Laboratorio guiado

1. **Levanta el team server** en una VM aislada (lo poblaremos con Sliver en la próxima clase). Anota su IP interna.
2. **Despliega un redirector HTTPS con socat:**

```
bash socat TCP4-LISTEN:443,fork,reuseaddr TCP4:10.10.0.5:443
```

donde `10.10.0.5` es el team server. El objetivo solo verá el redirector. 3. **Redirector filtrante con Nginx.** Configura `proxy_pass` solo para las URIs de tu perfil C2 y devuelve un `302` a un sitio legítimo para todo lo demás:

```
nginx location /api/v1/updates { proxy_pass https://10.10.0.5; } location / { return 302 https://www.ejemplo-legitimo.com; }
```

4. **Emite TLS válido** con `certbot` para el dominio del redirector; evita certificados autofirmados que delatan la operación.
5. **Separa funciones.** Define un redirector para *staging* (entrega inicial) y otro para *C2 de largo plazo*, de modo que quemar uno no exponga el otro.
6. **Prueba resiliencia.** Apaga el redirector primario y verifica que el implante rota al secundario (lo configuraremos con el perfil del C2 en la Clase 165).
7. **Registra la arquitectura** en un diagrama: objetivo → redirector(es) → team server, con dominios y puertos.

Ejercicios

1. Dibuja la arquitectura de una operación con 2 redirectores y separación staging/C2.
2. Escribe la regla de Nginx que reenvía solo `/jquery-3.6.0.min.js` al team server.
3. Explica por qué un certificado autofirmado es un mal OPSEC.
4. Compara canales HTTPS, DNS y SMB en fiabilidad y sigilo.
5. Diseña un plan de rotación de dominios ante un bloqueo.
6. Investiga el estado actual del domain fronting en un CDN popular y resume por qué está limitado.

Reto verificable

Despliega en tu lab una cadena **objetivo** → **redirector (TLS válido)** → **team server** donde el redirector solo reenvíe las URIs de tu perfil y redirija el resto a un sitio benigno. **Criterio de aceptación:** desde una máquina "víctima" del lab, una petición a la URI válida llega al team server, pero navegar a la raíz del redirector devuelve el sitio benigno; el team server nunca es alcanzable directamente desde la víctima.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El defensor bloquea todo de golpe	Sin separación por función; segmenta staging/C2/exfil
Certificado inválido en el navegador	Autofirmado; usa Let's Encrypt para TLS confiable
Team server aparece en logs del objetivo	No hay redirector o filtra mal; asegúrate de que solo el redirector es visible
Tráfico C2 evidente en el proxy web	Perfil por defecto; personaliza el malleable profile (Clase 165)
Redirector reenvía escaneos de bots	Falta filtrado por URI/User-Agent; añade reglas de descarte

Preguntas frecuentes

 **¿Por qué no conectar el implante directo al team server?** Porque cuando el defensor descubre la IP, la bloquea y pierdes todos los implantes. Los redirectores son sacrificables y protegen el activo central.

 **¿El domain fronting sigue siendo viable?** Muy limitado: la mayoría de CDNs lo han restringido. Hoy se prefieren dominios categorizados y perfiles maleables realistas.

 **¿DNS C2 es mejor que HTTPS?** DNS es sigiloso y sobrevive a muchos filtros, pero es lento y ruidoso en volumen. Se usa como long-haul/backup, no como canal principal interactivo.

Referencias

- Vest & Tubberville — *Red Team Development and Operations* (capítulo de infraestructura). <https://redteam.guide/>
- Bishop Fox — *Red Team infrastructure wiki*. <https://github.com/bluscreenofjeff/Red-Team-Infrastructure-Wiki>
- MITRE ATT&CK — *Command and Control* (TA0011). <https://attack.mitre.org/tactics/TA0011/>
- Nginx / socat documentación oficial.

Siguiente clase

Clase 165 - Frameworks C2: Cobalt Strike, Sliver y Mythic